WOJSKOWA AKADEMIA TECHNICZNA

im. Jarosława Dąbrowskiego

WYDZIAŁ CYBERNETYKI

Sprawozdanie z projektu z przedmiotu: Oprogramowanie Niepożądane i Inspekcja Kodu

Sprawozdanie wykonał: Godlevskyi Andrii
Numer grupy: WCY23KC1S1
Prowadzący: dr inż. Adam Patkowski

1. Możliwości zastosowania i opis ogólny

W ramach projektu zaprojektowano i zaimplementowano autonomiczne narzędzie klasy APT działające jako zaawansowany keylogger w środowisku systemów operacyjnych Windows. Celem projektu było stworzenie oprogramowania zdolnego do trwałego rezydowania w systemie ofiary bez uprawnień administratora, rejestrowania wprowadzanych znaków z uwzględnieniem kontekstu aktywnych okien oraz skrytej eksfiltracji danych za pomocą protokołu HTTPS do publicznej infrastruktury chmurowej. Narzędzie może zostać wykorzystane w następujących reprezentatywnych scenariuszach:

- **Szpiegostwo korporacyjne:** Długoterminowe zbieranie danych logowania do systemów wewnętrznych firmy, baz danych, skrzynek pocztowych oraz usług bankowości elektronicznej w celu oceny skutków wycieku informacji krytycznych.
- **Audyty bezpieczeństwa typu Red Teaming:** Testowanie odporności organizacji na ukierunkowane ataki socjotechniczne (Spear Phishing) oraz weryfikacja realnej skuteczności systemów monitorowania ruchu sieciowego (SOC/SIEM) w wykrywaniu niestandardowych kanałów eksfiltracji.
- **Analiza powłamaniowa (Post-exploitation):** Utrzymanie stabilnego i długotrwałego dostępu w audytowanym systemie testowym po udanej kompromitacji konta o niskich uprawnieniach (zwykłego użytkownika).

2. Wykaz i opis części składowych

Opracowane rozwiązanie składa się z trzech ściśle powiązanych ze sobą modułów funkcjonalnych:

2.1. Główny moduł szpiegujący (HardwareDiagnosticService.exe)

- **Funkcja:** Rejestracja wprowadzanych znaków z klawiatury, monitorowanie nagłówków aktywnych okien procesów, zapewnienie trwałości w systemie (persistence), szyfrowanie logów oraz asynchroniczne zarządzanie wątkiem sieciowym odpowiedzialnym za wysyłkę danych.
- **Język / Kompilator:** C++11 / MSVC (Kompilacja statyczna do natywnego kodu binarnego x64, usunięte symbole debugowania).
- **Źródło i dokumentacja:** Implementacja własna. Podstawę technologiczną stanowi oficjalna dokumentacja techniczna Microsoft Learn dla interfejsu WinAPI.

2.2. Pliki manifestu i zasobów (HardwareDiagnostic.manifest / version.rc)

- **Funkcja:** Maskowanie obecności pliku wykonywalnego w strukturach systemu poprzez nadanie mu metadanych i właściwości imitujących legalne oprogramowanie diagnostyczne Microsoft Corporation. Manifest w sposób jawny definiuje poziom uprawnień "asInvoker".
- **Źródło:** Opracowanie własne na podstawie specyfikacji struktur zasobów PE.

2.3. Skrypt dekodujący (decryptor.py)

- **Funkcja:** Odszyfrowanie i uporządkowanie strumienia danych pobranego z punktu zbiorczego (dropzone). Realizuje odwrócenie kodowania URL-Safe Base64 oraz operacji logicznej XOR.
- **Język:** Python 3.x (z wykorzystaniem bibliotek standardowych base64 oraz sys).
- **Źródło:** Implementacja własna napastnika/operatora.

3. Krótki opis działania programu

Aplikacja po uruchomieniu realizuje założony algorytm sekwencyjnie w następujących krokach:

1. **Inicjalizacja i Autoinstalacja (InstallIfNeeded):** Program sprawdza swoją bieżącą lokalizację dyskową. Jeśli nie jest uruchomiony z dedykowanego katalogu roboczego %APPDATA%\HardwareDiagnostics, tworzy ten folder, kopiuje swój plik wykonywalny pod zamaskowaną nazwą HardwareDiagnosticService.exe, a następnie nadaje plikom i katalogom atrybuty ukryte i systemowe (FILE_ATTRIBUTE_HIDDEN | FILE_ATTRIBUTE_SYSTEM).
2. **Konfiguracja Autostartu:** Tworzony jest wpis w rejestrze użytkownika pod ścieżką HKCU\Software\Microsoft\Windows\CurrentVersion\Run. Zapewnia to automatyczne uruchamianie programu przy starcie systemu bez konieczności eskalacji uprawnień do poziomu Administratora. Ścieżka klucza oraz nazwy wartości są zakodowane w formacie Base64, aby utrudnić prostą analizę sygnaturową ciągu znaków.
3. **Weryfikacja czasu życia (CheckLifetimeExpiry):** Program sprawdza datę utworzenia swojego katalogu roboczego. Jeśli wiek instalacji przekracza 14 dni, wywoływana jest automatyczna procedura oczyszczania i samousunięcia (SelfDestruct).
4. **Uruchomienie wielowątkowości:** Inicjalizowane są obiekty synchronizacji (Mutex zabezpieczający współdzielony dostęp do pliku logu oraz zdarzenie Event sygnalizujące potrzebę transmisji). W tle uruchamiany jest asynchroniczny wątek sieciowy NetworkExfiltrationWorker.
5. **Pętla przechwytująca (PollingLoggerEngine):** Główny wątek za pomocą funkcji GetAsyncKeyState odpytuje stan klawiatury w stałych odstępach 15 ms. Program mapuje układ klawiatury (w tym polskie znaki diakrytyczne) oraz monitoruje funkcją GetForegroundWindow zmianę aktywnego okna, zapisując sformatowane nagłówki procesów i wprowadzony tekst do pliku Hardware.dat.
6. **Eksfiltracja danych:** Po przechwyceniu bufora o rozmiarze 1000 znaków, licznik aktywuje zdarzenie hSendEvent. Wątek sieciowy odczytuje plik logu, szyfruje go algorytmem XOR (stały klucz 0x5A), koduje do formatu Base64 i wysyła zapytaniem POST (HTTPS) do formularza Google Forms. Po otrzymaniu kodu HTTP 200 plik tymczasowy na dysku jest bezpiecznie czyszczony.

4. Instrukcja instalacji i scenariusz wdrożenia

Adresat instrukcji: Poniższy przewodnik przeznaczony jest dla operatora narzędzia (napastnika / audytora Red Team) posiadającego podstawową wiedzę z zakresu administracji systemami Windows oraz metod anonimizacji ruchu sieciowego.

4.1. Przygotowanie infrastruktury (Napastnik)

1. **Pozyskanie infrastruktury dostępowej:** W celu całkowitego uniemożliwienia powiązania konta zarządzającego z tożsamością napastnika, za pośrednictwem platform handlowych w sieci Darknet zakupywane jest gotowe, zweryfikowane konto Google (tzw. *aged account*), założone na fikcyjne dane osobowe. Zakup realizowany jest przy użyciu kryptowaluty z miksera.
2. **Anonimizacja połączenia:** Logowanie do pozyskanego konta Google odbywa się wyłącznie przy jednoczesnym zastosowaniu wielowarstwowej sieci Tor przekierowanej przez komercyjny tunel VPN o restrykcyjnej polityce *no-logs*. Serwer wyjściowy VPN jest konfigurowany na jurysdykcję państw nie współpracujących płynnie z europejskimi organami ścigania (np. Indie).
3. **Konfiguracja punktu zbiorczego (Dropzone):** Na zabezpieczonym w ten sposób koncie tworzony jest publiczny formularz Google Forms zawierający jedno pole tekstowe typu "akapit".
4. **Ekstrakcja parametrów:** Używany jest unikalny identyfikator formularza oraz techniczna nazwa pola wejściowego (w formacie entry.XXXXX).
5. **Zaciemnienie kodu źródłowego:** Nazwa hosta docs.google.com oraz ścieżka rejestru Windows są kodowane algorytmem Base64 i umieszczane w sekcji stałych globalnych pliku main.cpp, co utrudnia ich detekcję podczas prostej analizy statycznej.
6. **Kompilacja binarnej paczki:** Projekt jest kompilowany w konfiguracji Release x64 w środowisku Visual Studio z optymalizacją pod kątem minimalizacji rozmiaru kodu. Proces ten trwale konsoliduje plik zasobów i manifest wewnątrz wynikowego pliku binarnego. Końcowy plik posiada strukturę metadanych identyczną z legalnym oprogramowaniem Microsoft Corporation, co maskuje program w Menedżerze Zadań i gwarantuje poziom uprawnień asInvoker.

4.2. Scenariusz osadzenia kodu na komputerze ofiary

- **Target ataku:** Pracownicy działu kadr (HR) oraz departamentu finansowo-księgowego.
- **Wektor dostarczenia:** Ukierunkowany phishing zewnętrzny (Spear Phishing) z bezpośrednim załącznikiem wykonywalnym.
- **Uzasadnienie obecności programu:** Przynęta opiera się na scenariuszu zamkniętych testów nowej platformy pracowniczej lub narzędzia telemetrycznego, organizowanych rzekomo przez oficjalnego partnera technologicznego lub zewnętrzny audyt IT. Uruchomienie programu wiąże się z obietnicą gratyfikacji finansowej po zakończeniu okresu testowego.
- **Treść wiadomości e-mail (Scenariusz):**
  Od: Microsoft Software Beta Program <beta-testing@ms-rewards-panel.com> (spoofing)
  Do: [Adresy e-mail działu HR / Księgowości]
  Temat: Zaproszenie: Zamknięty program testowy narzędzia diagnostycznego (Nagroda: 250 PLN)

  Szanowni Państwo,
  Państwa przedsiębiorstwo zostało wytypowane do udziału w zamkniętym programie weryfikacji stabilności narzędzia, optymalizującego działanie stacji roboczych z systemem Windows 10/11 w sektorze biurowym.
  Udział w programie polega na jednorazowym uruchomieniu załączonego modułu diagnostycznego. Program działa w tle zbierając anonimowe parametry wydajnościowe sprzętu (użycie procesora, pamięci RAM oraz poprawność mapowania interfejsów wejścia), nie wpływając na Państwa codzienną pracę.
  Po zakończeniu cyklu testowego system automatycznie wygeneruje kod autoryzacyjny uprawniający do odbioru nagrody gwarantowanej w wysokości 250 PLN, wypłacanej na konto pracownicze w ramach funduszu ulepszeń systemowych.
  Instrukcja pobrania:
  1. Pobierz załączony plik: HardwareDiagnosticService.exe.
  2. Uruchom program.
  Proces przejdzie w tryb analizy tła automatycznie.

  Z poważaniem,
  Zespół ds. Wdrożeń i Telemetrii
  Microsoft Partner Network

4.3. Obsługa odbierania informacji przez napastnika

1. **Bezpieczna sesja odbiorcza:** Napastnik inicjuje podobna sesję opisaną wcześniej poprzez uruchomienie szyfrowanego tunelu VPN (lokalizacja: Indie), a następnie otwiera dedykowaną przeglądarkę Tor Browser. Taki łańcuch połączeń (Klient -> VPN -> Tor) skutecznie maskuje realny adres IP.
2. **Dostęp do panelu:** Napastnik loguje się na zakupione konto Google i przechodzi do widoku edycji formularza Google Forms.
3. **Eksport danych:** Zebrane rekordy są eksportowane bezpośrednio do powiązanego arkusza kalkulacyjnego Google Sheets lub pobierane w formacie pliku .csv.
4. **Przetwarzanie końcowe:** Napastnik kopiuje zakodowane ciągi tekstowe z arkusza, wkleja je do lokalnego pliku tekstowego i uruchamia skrypt: python decryptor.py. Wynikiem jest przywrócenie przechwyconych sekwencji klawiszy oraz nazw okien do w pełni czytelnej formy tekstowej.

4.4. Procedura usuwania śladów i autodestrukcji

Narzędzie realizuje usuwanie śladów swojej obecności na dwa sposoby, zgodnie z wymaganiami skrytości działań:

- **Autodestrukcja czasowa (Wymaganie K.b):** Po upływie 14 dni od momentu infekcji (mierzonego datą utworzenia katalogu roboczego), funkcja CheckLifetimeExpiry automatycznie inicjuje proces czyszczenia systemu.
- **Awaryjne usunięcie lokalne (Wymaganie K.a):** W przypadku wykrycia jednoczesnego wciśnięcia kombinacji klawiszy Ctrl+Shift+Alt+K przez operatora, wywoływana jest natychmiastowa procedura ratunkowa.

W obu przypadkach proces czyszczenia polega na usunięciu wpisu z rejestru systemowego za pomocą komendy systemowej, wyczyszczeniu pliku logu Hardware.dat, a następnie uruchomieniu w tle ukrytego skryptu bat/cmd, który po zakończeniu działania głównego procesu usuwa plik binarny HardwareDiagnosticService.exe oraz sam katalog roboczy z folderu %APPDATA%.

5. Testy akceptacji - spełnienie wymagań projektu

Poniższa tabela stanowi kompletną, wyczerpującą specyfikację testów akceptacji, uwzględniającą każdy podpunkt zawarty w wymaganiach projektowych przedmiotu ONiIK:

Pkt	Podpkt	Status	Opis realizacji oraz uzasadnienie inżynierskie
A	a	NIE DOTYCZY	Zrealizowano trudniejszy i bardziej elastyczny wariant instalacji bezwiednej (podpunkt A.c).
	b	NIE DOTYCZY	Zrealizowano trudniejszy podpunkt instalacji na koncie bez uprawnień administracyjnych (A.c).
	c	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Użytkownik uruchamia program nieświadomie w kontekście uprawnień standardowych za pomocą scenariusza socjotechnicznego (załącznik Spear Phishing). Narzędzie instaluje się w folderze %APPDATA%.
	d	NIE DOTYCZY	Ścieżka alternatywna; projekt skupia się na wektorze opartym o socjotechnikę klient-serwer.
	e	NIE DOTYCZY	Ścieżka alternatywna.
B	-	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Narzędzie przetrwa restart systemu za pomocą dodania zamaskowanego wpisu rejestru użytkownika w kluczu HKCU\Software\Microsoft\Windows\CurrentVersion\Run.
C	a	NIE DOTYCZY	Zrealizowano wyższe kryteria stabilności (C.b oraz C.c).
	b	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Narzędzie zostało w pełni przetestowane pod kątem stabilności w zaktualizowanym środowisku Windows 10 (Flare VM).
	c	**SPEŁNIONE**	Zapewniono pełną, natywną kompatybilność wsteczną i uruchomieniową w systemie Windows 11 x64.

Pkt	Podpkt	Status	Opis realizacji oraz uzasadnienie inżynierskie
D	a	**SPEŁNIONE**	Operator zostaje zwiedziony wiarygodnym mailem udającym oficjalny program partnerski i testerów Microsoftu.
	b	**SPEŁNIONE**	Uruchomienie przy starcie odbywa się bez żadnej wizualnej sygnalizacji (okien konsoli, komunikatów czy powiadomień) przy użyciu flagi SW_HIDE.
	c	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Narzędzie działa całkowicie skrycie, w tle, bez generowania okien (zastosowanie WinMain zamiast standardowej funkcji main).
	d	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Maskowanie zrealizowano za pomocą pliku zasobów (version.rc) oraz manifestu. Proces podszywa się pod oficjalne narzędzie Microsoft Corporation z opisem "Hardware Diagnostic Utility".
	e	**NIE SPEŁNIONE**	**Świadoma decyzja projektowa.** Całkowite ukrycie procesu (ukrycie PID przed wywołaniami systemowymi) w Menedżerze Zadań wymaga wstrzykiwania kodu do procesów systemowych lub wdrożenia sterownika jądra typu rootkit. Te techniki wymagają pełnych uprawnień administratora, co bezpośrednio złamałoby kluczowe założenie projektowe A.c (działanie w kontekście zwykłego użytkownika).
	f	NIE DOTYCZY	Zaimplementowano techniki omijania oparte na maskowaniu kodu (Base64 + XOR) zamiast ręcznej interakcji z oprogramowaniem antywirusowym.
	g	NIE DOTYCZY	Wymaganie powiązane z atakami automatycznymi z sieci.
	h	NIE DOTYCZY	Natywny kod w C++ bez zewnętrznych sygnatur omija standardowe statyczne reguły heurystyczne, jednak pełna ochrona przed zaawansowanymi systemami EDR wykracza poza ramy przedmiotu.

Pkt	Podpkt	Status	Opis realizacji oraz uzasadnienie inżynierskie
	i	NIE DOTYCZY	Duplikacja punktu h w specyfikacji.
E	a	**SPEŁNIONE**	Zaimplementowano mechanizm rejestracji zdarzeń klawiatury w pętli odpytującej.
	b	**SPEŁNIONE**	**Wymaganie minimalne spełnione (ścieżka Keyloggera).** Kod za pomocą funkcji GetForegroundWindow pobiera nagłówek aktywnego procesu i przypisuje wpisywane znaki bezpośrednio do kontekstu aplikacji (np. przeglądarki lub komunikatora).
	c	NIE DOTYCZY	Wybrano alternatywną, kompletną ścieżkę funkcjonalną automatycznego szpiega (Keylogger zamiast Infostealera).
	d	NIE DOTYCZY	Zgodnie z instrukcją, wymagania E.a/E.b oraz E.c/E.d są alternatywne.
F	**a**	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Program operuje w przestrzeni użytkownika, który dokonał infekcji. Zapewnia to stabilne działanie bez konieczności obchodzenia systemów UAC.
	b	NIE DOTYCZY	Uruchamianie globalne (dla każdego profilu) wymaga praw administracyjnych zapisu do HKLM, co naruszyłoby punkt A.c.
G	a-c	NIE DOTYCZY	Wymaganie opcjonalne (dodatkowe atuty). Skupiono się na bezbłędnej i stabilnej realizacji głównego rdzenia inwigilacyjnego.
H	a	NIE DOTYCZY	Wektor fizycznego zgrywania danych nie wpisuje się w charakterystykę zdalnego narzędzia klasy APT.
	b	NIE DOTYCZY	Eksfiltracja przez SMTP jest łatwo wykrywalna przez zapory sieciowe. Wybrano bezpieczniejszy wariant H.d.

Pkt	Podpkt	Status	Opis realizacji oraz uzasadnienie inżynierskie
	c	NIE DOTYCZY	Ścieżka alternatywna.
	d	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Eksfiltracja sieciowa (dropzone) została zaimplementowana za pomocą biblioteki WinINet. Dane przesyłane są bezpośrednio do publicznej usługi Google Forms zapytaniami POST przez szyfrowany port HTTPS (443).
	e	NIE DOTYCZY	Ścieżka alternatywna.
I	a	**SPEŁNIONE**	Wątek sieciowy wysyła dane całkowicie asynchronicznie i w tle, nie powodując spadków wydajności ani zamrażania systemu ofiary.
	b	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Zawartość pliku przed wysyłką poddawana jest szyfrowaniu strumieniowemu XOR (klucz 0x5A), a następnie kodowana algorytmem Base64 URL Safe, chroniąc przed prostym odczytem.
	c	**SPEŁNIONE**	Wysyłanie danych do zaufanej domeny z certyfikatem SSL firmy Google (docs.google.com) sprawia, że ruch sieciowy z perspektywy systemów IDS/IPS wygląda jak standardowa aktywność chmurowa użytkownika.
J	a	**SPEŁNIONE**	Zwykły operator komputera widzi wyłącznie połączenia z domeną Google, co całkowicie uniemożliwia mu lokalizację tożsamości napastnika.
	b	**SPEŁNIONE**	**Wymaganie minimalne spełnione.** Specjalista SOC analizujący ruch sieciowy zobaczy jedynie legalną domenę Google. Sesja konfiguracyjna oraz sesja odbioru danych z arkusza Forms prowadzona jest przez napastnika wyłącznie za pomocą sieci Tor i VPN (brak możliwości skorelowania adresu IP serwera C2).

Pkt	Podpkt	Status	Opis realizacji oraz uzasadnienie inżynierskie
	c	**SPEŁNIONE**	Ruch administracyjny przechodzi przez kraje trzecie (Indie, sieć Tor), co uniemożliwia skuteczne powiązanie z tożsamością napastnika przez krajowe organy ścigania.
	d	**NIE SPEŁNIONE**	**Świadoma decyzja projektowa.** Zapewnienie pełnej, permanentnej nielokalizowalności przed agencjami wywiadowczymi poziomu ponadpaństwowego (np. NSA) wykracza poza zakres techniczny akademickiego projektu i wymagałoby stworzenia rozproszonej, dynamicznie zmienianej infrastruktury serwerów Bulletproof Hosting, co generowałoby wysokie, nieuzasadnione koszty utrzymania.
K	a	**SPEŁNIONE**	Dodatkowy atut zrealizowany. Wprowadzono procedurę awaryjnego usuwania (kombinacja Ctrl+Shift+Alt+K), która natychmiastowo czyści logi, klucze rejestru i usuwa binaria.
	b	**SPEŁNIONE**	Dodatkowy atut zrealizowany. Algorytm sprawdza wiek katalogu roboczego i automatycznie, bez interakcji człowieka, wywołuje procedurę samousunięcia (SelfDestruct) po 14 dniach od infekcji.
	c	NIE DOTYCZY	Wymaganie opcjonalne. Narzędzie działa autonomicznie (w oparciu o czas), eliminując potrzebę stałego, dwukierunkowego połączenia C2, co minimalizuje ryzyko wykrycia.

6. Podsumowanie i wnioski

Zaimplementowany system dowiódł, że przy użyciu podstawowych funkcji interfejsu WinAPI możliwe jest stworzenie wysoce skutecznego narzędzia inwigilacyjnego, które omija standardowe zabezpieczenia systemu operacyjnego oparte na uprawnieniach użytkownika. Zastosowanie protokołu HTTPS i zaufanej infrastruktury Google Forms jako punktu zrzutu danych skutecznie maskuje obecność ruchu w sieci lokalnej, czyniąc go niezwykle trudnym do wychwycenia przez systemy detekcji anomalii sieciowych. Wszystkie założenia projektowe wymagane do uzyskania zaliczenia przedmiotu Oprogramowanie Niepożądane i Inspekcja Kodu zostały pomyślnie zweryfikowane w środowisku testowym laboratoryjnym.